

HTTPS·Webhook Ingress

완료 보고서

외부 HTTPS 전환과 서명·중복 방지 Webhook 수신 경로

VALIDATED · HTTPS 200 · HTTP 308 · Signed Webhook 202 · Duplicate 409 · Reboot Recovery PASS

항목	값
GitHub Issue	#14 외부 HTTPS·Webhook 접속 경로 구성
검증일	2026-07-31
외부 URL	https://techflow.ablecloud.io
내부 URL	http://172.16.0.231:8080
상태	VALIDATED

이 문서에는 계정 비밀번호, API Key, HMAC Secret과 서버의 실제 .env 값이 포함되지 않는다.

1. 결과 요약

Issue #14 완료 기준인 HTTPS를 통한 서명 Webhook 수신과 보안·운영 절차 문서화를 모두 충족했다.

영역	적용	판정
HTTP 전환	호스트 한정 308, 경로·쿼리 보존	PASS
TLS	Cloudflare → Origin Full (strict)	PASS
Webhook	HMAC-SHA256 + Timestamp + Event ID	PASS
중복 방지	Redis SET NX EX, TTL 86,400초	PASS
서비스	App-Worker-DB-Redis-Gateway-Ingress	6/6 healthy
복구	서비스 재시작과 서버 재부팅	PASS
비밀정보	서버 .env 0600, 로그 노출 0	PASS

영향 범위

- Cloudflare 규칙은 techflow.ablecloud.io 호스트에만 적용했다.
- Zone 전체 SSL 설정은 변경하지 않아 다른 서비스의 동작을 유지했다.
- 고객 공개 여부는 별도 제품 의사결정이며 구현 완료 기준과 분리했다.

2. 요청 경로와 책임

호출	책임	실패 시
Cloudflare Edge	HTTP 308, Edge TLS, 호스트 분기	외부 요청 차단
OpenResty Origin	유효한 Origin TLS와 사설 전달	Cloudflare 526/연결 실패
Caddy Ingress	Webhook과 UI 경로 분리, 보안 헤더	502 또는 Health 실패
Event Gateway	서명·시각·중복 검증	400/401/409/503
Redis	Event ID 원자적 선점과 TTL	Gateway Fail Closed
Activepieces	검증 완료 이벤트의 Flow 실행	실행 결과는 별도 상태로 관리

Worker 연결

App은 공개 기준 URL을 사용하지만 Worker는 Compose 내부 URL `http://app:80`을 사용한다. 외부 Edge 장애가 내부 Flow 실행 연결을 끊지 않도록 런타임 경로를 분리했다.

네트워크 노출

- Host에는 172.16.0.231:8080만 바인딩한다.
- 공개 Origin의 80-443만 사용하며 외부 8080은 닫혀 있다.
- PostgreSQL과 Redis는 Compose 내부 Network에만 존재한다.

3. Webhook 보안 계약

서명 입력: "<unix-timestamp>.<raw-body>" · 알고리즘: HMAC-SHA256

항목	설정
Timestamp 헤더	X-TechFlow-Timestamp
Event ID 헤더	X-TechFlow-Event-Id
Signature 헤더	X-TechFlow-Signature: sha256=<hex>
허용 시각차	300초
중복 방지 TTL	86,400초
최대 Body	1,048,576 bytes
Redis 장애	Fail Closed · 503
로그	Request ID·Event ID·상태만 기록

검증 순서

- 경로, 메서드, 필수 헤더와 Body 크기를 확인한다.
- Timestamp 신선도를 확인한 뒤 HMAC을 상수 시간 비교한다.
- Redis에서 Event ID를 원자적으로 선점한 신규 이벤트만 수락한다.
- 선택적 Upstream 전달 시 Secret 헤더는 제거한다.

4. 통합 검증

ID	검증	HTTP/수치	결과
V1	HTTP to HTTPS redirect	308	PASS
V2	Public HTTPS TLS and UI	200	PASS
V3	Public and private health endpoints	200	PASS
V4	Valid signed webhook	202	PASS
V5	Duplicate event rejection	409	PASS
V6	Invalid signature rejection	401	PASS
V7	Stale timestamp rejection	401	PASS
V8	Missing signed headers rejection	400	PASS
V9	Gateway unit tests	4/4	PASS
V10	Service restart recovery		PASS
V11	Host reboot recovery		PASS
V12	Runtime secret log exposure	0	PASS

V1-V12 전체 PASS. 정상 수신뿐 아니라 중복·위조·오래된 요청의 거부와 재부팅 복구까지 확인했다.

브라우저 검증

외부 HTTPS 주소에서 인증된 Activepieces 프로젝트 화면과 영문 UI가 정상 로드되는 것을 확인했다.

5. 배포 자산과 서비스

서비스	이미지	상태
app	ghcr.io/activepieces/activepieces:0.86.3	healthy
worker	ghcr.io/activepieces/activepieces:0.86.3	healthy
postgres	pgvector/pgvector:0.8.0-pg14	healthy
redis	redis:7.0.7	healthy
event-gateway	techflow-event-gateway:local	healthy
ingress	caddy:2.8.4-alpine	healthy

재현 가능한 자산

자산	역할
compose.yml	6개 서비스, Network, Health와 제한 설정
Caddyfile	Webhook/UI 경로 분기와 보안 헤더
gateway.py	HMAC-Timestamp-Redis 중복 검증
configure-ingress.sh	공개 URL과 서버 비밀번호 안전 구성
verify-webhook.sh	202-409-401-401-400 자동 판정
verify-ingress.sh	HTTP-HTTPS-Health-Webhook 통합 판정
Runbook + JSON	운영 절차와 구조화 검증 증적

6. 보안·복구 판정

통제	적용
TLS 범위	TechFlow 호스트 한정 Full (strict)
HTTP 전환	308로 메서드와 본문 의미 보존
Gateway 실행	비루트, 읽기 전용, no-new-privileges
중복 상태	Redis 원자적 선점, 장애 시 Fail Closed
비밀값	.env 0600, 저장소·문서·로그 미포함
데이터 포트	PostgreSQL-Redis Host 미노출
로그 검사	Secret 노출 0건

복구 검증

- Ingress와 Event Gateway 재시작 뒤 외부 통합 검증을 다시 통과했다.
- 서버 재부팅 뒤 6개 서비스와 Worker Polling이 자동 복구되었다.
- 재부팅 뒤에도 HTTP 308, HTTPS 200, Webhook 202/409/401/401/400을 재확인했다.

롤백은 호스트 전용 Cloudflare 규칙 비활성화와 배포 전 구성 복원으로 수행하며 데이터 볼륨과 Secret은 삭제하지 않는다.

7. 완료 판정과 다음 단계

최종 판정: VALIDATED. Issue #14를 종료하고 Secret 수명주기와 첫 GitHub Webhook Flow 실증으로 진행할 수 있다.

검토 자산

- docs/runbooks/https-webhook-ingress.md
- docs/reports/issue-14-https-webhook-validation.md
- docs/decisions/https-webhook-ingress.json
- deploy/compose/activepieces/event-gateway/
- output/issue-14-artifact-manifest.json

후속 이슈

이슈	목표
#15	Secret 저장·교체·폐기
#16	PostgreSQL-Redis 백업과 복구 훈련
#17	로그·메트릭·경보
#18	버전·Digest·회귀 정책
#19	GitHub PR Merge Webhook 첫 업무 Flow

보안 확인

공개 산출물에는 SSH 비밀번호, Activepieces 계정 비밀번호, API Key, HMAC Secret과 서버의 실제 .env 값이 포함되지 않는다.